

Software Development Vulnerability Management Policy

(Last Updated February 2026)

Purpose

Our Software Development Vulnerability Management Policy aims to establish standards for systematically examining software source code, focusing on identifying and rectifying potential security vulnerabilities, code inefficiencies, and deviations from established coding standards. This policy aims to enhance our software products' security, performance, and maintainability, thereby minimizing the risks associated with insecure coding practices and software defects. Through implementing this policy, we commit to developing secure, high-quality software that aligns with industry best practices, regulatory compliance standards, and the expectations of our stakeholders while upholding the integrity, confidentiality, and availability of our organizational digital assets.

Scope

The Software Development Vulnerability Management Policy applies to all software code developed or utilized within our organization, including in-house development, third-party applications, and open-source software. This policy covers the analysis of code for security vulnerabilities, coding errors, and adherence to coding standards and best practices. It applies to all software development teams, software architects, programmers, and individuals responsible for reviewing and maintaining software code. The policy outlines the procedures, tools, and methodologies for code analysis, including static analysis, dynamic analysis, and manual code reviews. Compliance with this policy is mandatory to identify and mitigate potential security risks and vulnerabilities in software code. Any exceptions or deviations from this policy must be approved by the designated authority responsible for software code analysis and security.

Safeguards

To achieve the organization's overall mission, and the purpose of this cybersecurity policy, the organization shall:

- SDV-01 Maintain an issue-tracking system for each cybersecurity vulnerability identified in the organization's custom software applications.
- SDV-02 Ensure that the organization's issue-tracking system tracks cybersecurity vulnerabilities identified in its custom software applications and tracks the criticality of each custom software application to assist the organization with threat modeling.
- SDV-03 Ensure that the organization's issue-tracking system tracks cybersecurity vulnerabilities identified in its custom software application, calculating the criticality of each vulnerability to assist the organization with threat modeling.
- SDV-04 Maintain a software application code vulnerability scanner to scan each organization's custom software application for cybersecurity vulnerabilities.
- SDV-05 Ensure that each of the organization's software application development teams utilizes its software application code vulnerability scanner to scan each of their custom software applications, including relevant application source code and associated application deployment and configuration artifacts (such as infrastructure-as-code definitions, container build files, and deployment descriptors), where applicable.
- SDV-06 Ensure that vulnerability identification and testing activities for custom software applications include application programming interfaces (APIs), including testing for authentication bypass, authorization failures, and injection vulnerabilities.
- SDV-07 Ensure that each cybersecurity vulnerability identified by the software application code vulnerability scanner is reported to the organization's issue-tracking system.

- SDV-08 Maintain an approved artifact repository to store and manage the software artifacts generated by the organization's software development teams.
- SDV-09 Ensure the organization's approved artifact repository maintains an inventory of the software libraries, third-party modules, and other components used by the organization's software application development teams.
- SDV-10 Ensure the organization's approved artifact repository is capable of generating a Software Bill of Materials (SBOM) for each software artifact created by the organization's software development teams.
- SDV-11 Maintain Software Composition Analysis (SCA) tool(s) to identify, analyze, and track software libraries, third-party modules, and other components used in the organization's custom software applications.
- SDV-12 Ensure the organization's Software Composition Analysis (SCA) tool(s) identify whether approved software libraries and third-party modules used by the organization's software application development teams are actively maintained and supported.
- SDV-13 Ensure the organization's Software Composition Analysis (SCA) tools(s) identify known cybersecurity vulnerabilities in approved software libraries and third-party modules used by the organization's software application development teams.
- SDV-14 Ensure the organization's Software Composition Analysis (SCA) tool(s) reports each cybersecurity vulnerability identified in approved software libraries and third-party modules to the organization's issue-tracking system.
- SDV-15 Maintain a process for individuals inside or outside the organization to report software application vulnerabilities to the organization's issue-tracking system.
- SDV-16 Maintain documented Service Level Agreements (SLAs) that define the organization's timing targets for mitigating cybersecurity vulnerabilities discovered in the organization's custom software applications.

- SDV-17 Ensure the organization's documented Service Level Agreements (SLAs) require that each cybersecurity vulnerability tracked in the organization's issue-tracking system is remediated within the time frames defined by those SLAs.
- SDV-18 Ensure the organization's documented Service Level Agreements (SLAs) require that cybersecurity vulnerabilities identified in approved software libraries and third-party modules used by the organization's custom software applications are remediated, including through the application of cybersecurity-related updates, within the time frames defined by those SLAs.
- SDV-19 Ensure the organization's documented Service Level Agreements (SLAs) require that any exceptions to the organization's vulnerability remediation time frames are formally documented, approved, and tracked in the organization's issue-tracking system.
- SDV-20 Ensure the organization's documented Service Level Agreements (SLAs) require that the status of each cybersecurity vulnerability tracked in the organization's issue-tracking system is reported to the appropriate stakeholders on a regular basis.

Policy Sanctions

Non-compliance with this policy may result in disciplinary action in line with our corporation's human resources procedures. Consequences may range from mandatory refresher training and written warnings to temporary suspension of remote access privileges and, in severe cases, termination of employment or contractual obligations. Individuals could be subject to legal consequences under applicable laws if violations involve illegal activities. These sanctions emphasize the critical importance of cybersecurity, the individual's role in protecting our digital assets, and the potential risks associated with policy violations. Enforcement will be consistent and impartial, with the severity of the action corresponding directly to the seriousness of the breach.

